Revisión crítica: especificación frente al código

Sprints 7 a 9 · 29 de octubre de 2026 · `main` en `f3fd2d1` (CS-31, CS-18, CS-21, CS-16 y CS-34) · Regla 5 de CLAUDE.md

Resumen

Tres revisiones independientes leyeron el código frente a SPEC.md, las reglas AR, los ADR y la documentación:

- base de datos, seguridad y privacidad;
- dominio, dinero, impuesto y arquitectura del backend;
- frontend, infraestructura, CI y documentación.

Cada hallazgo se comprobó en el código. Los importantes se reprodujeron con pruebas mínimas contra PostgreSQL real o se verificaron otra vez antes de escribir este informe.

0 bloqueantes, 7 importantes nuevos, 1 importante que sigue abierto de la revisión anterior (I1) y unos 25 menores. El cálculo del impuesto y de los saldos es correcto y usa una sola aplicación de pagos. El aislamiento entre cuentas, el contexto del inquilino y el libro de solo inserción se sostienen con los roles reales.

Cinco decisiones son tuyas (regla 2):

- volver a recibir los recordatorios después de darse de baja (I22);
- anular un contrato registrado por adelantado (I23);
- el aviso al anular un cobro ya declarado (I24);
- la base declarada en el pago a SUNAT (I25);
- dos textos de "después de declarar" y dos acciones de un solo toque.

Lo demás lo resuelvo yo (regla 1) en PR pequeños, en el orden de "Plan propuesto", antes del Sprint 10. No hay nada desplegado ni datos reales, así que ningún hallazgo es explotable hoy.

Hallazgos importantes

Id	Hallazgo	Corrección	Cuándo
I21	**Hueco.** Rotar la clave de los enlaces del inquilino no invalida los enlaces y rompe el botón de WhatsApp. • El token se firma con la clave de cada enlace (`key_id`) y la base lo resuelve solo por su hash. • Al retirar una clave, los enlaces viejos siguen abriendo el portal. • Mostrar el enlace o preparar un mensaje con él falla con 500 (`KeyError` en `crypto.py:113`; reproducido). • El plan de incidentes no menciona esta clave. Si el servidor se ve comprometido, la reacción natural (rotar) deja vigentes todos los enlaces.	• Plan de incidentes: revocar todos los enlaces y luego rotar. • Si la clave de un enlace ya no existe, tratarlo como "sin enlace" y emitir uno nuevo en vez de fallar. • Prueba de rotación.	Ahora · regla 1

I22	**Hueco.** Darse de baja de los recordatorios de impuesto es para siempre. Un toque en `/baja` crea la supresión, y ningún código ni pantalla la quita: `casero_app` solo tiene SELECT e INSERT en `email_suppressions`. Es una función pagada y central, y una declaración olvidada puede costar una multa. Al resumen diario (CS-17) le pasará lo mismo.	Una casilla "Recibir los recordatorios de SUNAT por correo" en Mis datos, que borre solo la baja del propio usuario para ese tipo de correo. Requiere DELETE en `email_suppressions` (tabla de roles y AR-14).	Antes de la beta · regla 2
I23	**Hueco.** Un contrato registrado por adelantado no se puede anular antes de que empiece: • terminarlo exige una fecha entre el inicio y hoy; • el fin previsto no puede ser anterior al inicio ni a hoy (reproducido: un contrato del 1 de diciembre no se puede deshacer en octubre). Mientras tanto ocupa la unidad, cuenta para el límite del plan (1 en el gratis) y cobra diciembre completo.	Permitir terminarlo con la fecha de hoy aunque sea anterior al inicio: se anulan sus rentas y lo cobrado queda "a devolver".	Ahora · regla 2
I24	**Hueco de SPEC sin dueño.** SPEC (Pagos, "Anulación") pide avisar al anular un cobro si ese mes ya tiene un pago a SUNAT, pero no existe: la anulación solo devuelve el pago, y ninguna historia lo incluye. Anular un saldo anterior de 2025 también cambia bases ya declaradas sin avisar. El arrendador se entera solo si vuelve a abrir Formularios de SUNAT.	• Un puerto en `ledger.application` que implemente `tax` (AR-03). • Las anulaciones de pagos y de cargos devuelven si el mes ya tenía un pago a SUNAT. • La pantalla muestra el aviso, con un texto para tu aprobación.	Ahora, como cierre de CS-34 · regla 2
I25	**Hueco en SPEC (tu decisión de #91).** La "base declarada" que se guarda es la del momento en que se registra el pago a SUNAT, no la que se declaró. Ejemplo: • el arrendador declara con base 500; • luego registra un cobro tardío de ese mes; • y después registra su pago a SUNAT. Casero guarda la base nueva, la tarjeta dice "Falta pagar S/ 5" y nunca muestra el texto de rectificatoria.	El formulario pide confirmar el "Monto declarado (base)", prellenado con la base actual y editable; se guarda lo que el arrendador confirma.	Ahora · regla 2
I26	**Deuda.** CI se pone en rojo el 1 de enero de 2027. La prueba de punta a punta abre el mes actual, y 2027 no tiene reglas (la UIT sale en diciembre), así que la tarjeta no aparece. Edge es un check obligatorio, así que ningún PR se podría fusionar hasta cargarlas. Además, nada alerta de que faltan las reglas del año siguiente: solo existe la alerta del cronograma.	• La prueba usa un mes de 2026 fijo. • Alerta desde noviembre si faltan las reglas del año siguiente. • Nota en `tax-config.md`.	Ahora · regla 1

I27	**Accesibilidad (WCAG 2.5.3, nivel A).** El nombre accesible no contiene el texto visible: • "Corregir monto" se anuncia como "Corregir el monto de…"; • el botón de WhatsApp conserva su nombre mientras muestra "Preparando el mensaje…". Quien usa control por voz no puede activarlos, y axe no lo detecta.	Nombres que empiecen con el texto visible, y sin `aria-label` mientras se envía. Prueba con la regla.	Ahora · regla 1
I1	**Sigue abierto, y ahora pesa más.** El inicio de sesión espera hasta 30 s dentro de la transacción, con una conexión del pool (5 + 5) tomada. El correo de la cuenta también se envía dentro de la transacción. El bloqueo de la fila del límite por IP hace que los intentos simultáneos esperen con su conexión tomada. Una sola IP puede dejar sin conexiones a toda la API, y desde estos sprints eso incluye el portal del inquilino y WhatsApp.	Dormir y enviar fuera de la transacción (commit primero). Prueba de que un login lento no retiene una conexión.	Antes de la beta · regla 1

Hallazgos menores

Datos y seguridad

- **Pagos a SUNAT repetidos:** el mismo pago a SUNAT enviado dos veces a la vez da 409 en vez de 200, porque no hay bloqueo (reproducido por dos revisores). Es la misma falla que ya se corrigió en los cobros. Bloquear la fila de la cuenta antes de leer y copiar la prueba de concurrencia (ahora).
- **Escritura del inquilino:** en el contexto del inquilino se puede escribir `tenant_links.revoked_at`, no solo `last_used_at` como dicen tu decisión D7, SPEC y AR-16. Política RESTRICTIVE de UPDATE más su prueba (ahora; aplica una decisión tuya).
- **Caché del navegador:** las respuestas JSON de `/api` con documentos descifrados o con el enlace del inquilino no llevan `Cache-Control: no-store`, y un celular compartido podría guardarlas en caché. Agregarlo en los dos Caddyfile, con su prueba del borde (ahora).
- **Descifrado de más:** el aviso del inicio y el registro del pago a SUNAT descifran todos los documentos sin necesitarlos, cuando SPEC dice "solo en la tarjeta y en la exportación". Usar la lectura sin números, como el worker (ahora).
- **Exportación sin rastro:** la exportación con documentos completos no deja auditoría. Registrar una fila en `audit_log`, solo con nombres de campos (ahora).
- **Sentry:** los registros de librerías (`logentry`) siguen llegando a Sentry sin limpiar (verificado con un DNI de prueba), y el tope global de errores del navegador sigue pendiente (ahora, como estaba planeado).
- **Retiro del consentimiento:** retirarlo (CS-25) no frenará el portal, los mensajes ni los correos del worker. Decidir en CS-25 qué bloquea "bloqueada".
- **Sin cambios desde la revisión anterior:** el catálogo no revisa vistas ni membresías (I7, sin exposición hoy); `search_path` sin `pg_temp` (no explotable); políticas de cuenta para PUBLIC (CS-24).

Backend

- **Carrera con el trabajo de rentas:** un cambio de renta o una terminación puede cruzarse con el trabajo diario de rentas a las 00:00 del día 1 y cobrar la renta vieja (reproducido). Bloquear los contratos en ese trabajo (ahora).
- **Reintentos de los recordatorios:** son 3 intentos a 60 s, ante cualquier error, y si el worker está caído justo el día D-5 o D-1, ese aviso se pierde. Espaciar los reintentos, reintentar solo errores de correo y enviar uno de recuperación dentro de la ventana (ahora).
- **Dos casos de "después de declarar":** (a) "Cobraste S/ X más" aparece también cuando la base sube porque se anuló un saldo de 2025, sin dinero nuevo; (b) con el documento cambiado, la tarjeta y el correo muestran todo el tributo como pendiente y podrían llevar a pagar dos veces en vez de presentar el 1693 (decisión 5).

- **Pruebas que faltan:** el trabajo de recordatorios no se prueba junto con `build_jobs` y la hora de las 8:00, y las propiedades de Hypothesis no cruzan la medianoche de Lima ni permutan créditos (ahora).
- **Deuda que creció:** `api.py` tiene 946 líneas; hay validadores copiados en 5 módulos; `RucGroup` está dos veces; la renta de un período está en Python y en SQL. Se resuelve antes de CS-15, como estaba previsto.
- **Para CS-23:** "Meses pagados" necesitará revisar el plan por período, no solo al leer.

Web e infraestructura

- **Errores silenciosos:** anular o corregir un cargo cierra el formulario aunque el servidor lo rechace (409 o 422), sin mensaje.
- **Panel y WhatsApp:** el panel muestra "Enviar por WhatsApp" en contratos que solo deben saldos anteriores, donde el servidor responde "nada pendiente". Usar la misma regla que la página del contrato.
- **Portal del inquilino:** la consulta no depende del token, así que otro enlace en la misma pestaña muestra el estado anterior. El aviso de privacidad usa el nombre del arrendador como contacto mientras carga el del negocio.
- **Cobertura de la prueba de punta a punta:** no cubre `/i`, la página del contrato, Mensajes ni el service worker. Las pruebas del borde aprueban aunque falten `sw.js` y `registerSW.js`, y no prueban el `noindex` de `/baja` ni el modo de registro `closed`.
- **Foco y avisos:** el foco no va al primer campo al abrir anular, corregir o los formularios de SUNAT, y se pierde al revocar el enlace o al cancelar. El cambio de mes no se anuncia, algunos errores no están ligados a su campo y falta `maxLength` en el motivo de anulación.
- **Fallas ocultas:** el aviso de SUNAT desaparece si falla; el inicio hace 7 pedidos (los nombres podrían venir con el panel).
- **Textos:** "Cobros" significa cargos en la página del contrato y dinero cobrado en SUNAT; hay tres formas de "volver al inicio"; "ruc" sale en minúscula en un nombre accesible (decisión 5 para los de SUNAT).
- **Pruebas y límites:** Vitest se pasa del tiempo con mucha carga en paralelo. El límite de 5 MB se mide distinto en dos lugares del Caddyfile. Al enlace de privacidad del pie le falta la altura de 44 px.
- **Documentación:**
  - ADR-0002 (el inquilino no escribe), ADR-0006 (el mensaje ahora lo arma el servidor) y ADR-0007 (la exportación también descifra) están desactualizados;
  - SPEC dice que el worker no recibe claves, pero la purga de CS-25 descifra el correo de contacto;
  - SPEC cita `make load-tax-config`, que solo corre en local.

Estado de la revisión anterior

Id	Estado
I12, I13	Cerrados: AR-20 recorre los routers incluidos y exige CSRF; el commit ocurre antes de la respuesta (ADR-0012).
I14, I15	Cerrados en el código: el respaldo avisa solo si sube, `/api/health` consulta la base y el worker envía su heartbeat. Falta activarlos con tus cuentas.
I16 a I20	Cerrados: cobros antes del control con aviso, renovación, saldos anteriores imposibles, errores del pago en la pantalla, correo de privacidad. I23 es el caso que faltaba de I17.
F11	Parcialmente cerrado: el flujo del arrendador corre con las imágenes y la CSP de producción; faltan `/i` y el service worker.
Escrituras del inquilino	Cerrado con la migración 0009 (salvo el menor de `revoked_at`).

Pendientes tuyos	Siguen abiertos: • I5 (vouchers, en CS-19); • permisos de más de `casero_app` y `casero_worker` (antes de CS-23); • hash de IP de las aceptaciones (CS-25); • las dos políticas de privacidad (CS-25); • la gracia de la prueba gratis (CS-23).

Lo que está sólido

- **Impuesto:** las declaraciones reutilizan la aplicación de pagos de los saldos. Todo va en céntimos enteros con redondeo exacto, y 450.50 + 100.50 da base 551 y tributo 28. Los créditos y la deuda de 2025 o antes quedan fuera de la base, y la renta mínima se compara con enteros.
- **Enlace del inquilino:** HMAC sobre el id y el nonce; la base guarda solo el hash del token, que viaja en el fragmento y en `X-Tenant-Token`. Cada pedido del portal cuenta para el límite, y su respuesta nunca incluye RUC, correo, notas ni el token.
- **Contexto del inquilino de solo lectura:** políticas RESTRICTIVE por comando en todas las tablas, con pruebas de catálogo, meta y comportamiento.
- **Worker sin claves de cifrado:** agrupa por `doc_hmac`, escribe solo al dueño con correo confirmado, respeta las bajas y los rebotes, y la baja de un clic está probada de punta a punta.
- **Idempotencia y solo inserción:** cada creación usa el id del cliente con `ON CONFLICT`, y ningún camino nuevo edita ni borra el libro. Las escrituras de CS-31 bloquean la fila del contrato.
- **Borde de producción:** CSP estricta, sin referer, HSTS, `noindex` donde corresponde y sin registros de acceso. La prueba de punta a punta corre con axe sobre las imágenes de producción, y los 6 checks de CI son obligatorios.

Plan propuesto

Regla 1, en PR pequeños antes del Sprint 10:

1. **CI y 2027:** la prueba de punta a punta con un mes fijo, y la alerta de reglas del año siguiente (I26).
2. **Seguridad:**
   - rotación de la clave de enlaces (I21);
   - `no-store` en `/api`;
   - lectura sin números para el aviso y el pago a SUNAT;
   - `revoked_at` en el contexto del inquilino;
   - auditoría de la exportación;
   - Sentry `logentry` y el tope de errores del navegador;
   - bloqueo en los pagos a SUNAT.
3. **Sesiones:** I1, la espera y el correo fuera de la transacción.
4. **Worker:**
   - bloqueo de contratos en las rentas;
   - reintentos espaciados y aviso de recuperación;
   - pruebas con `build_jobs` y Hypothesis cerca de la medianoche.
5. **Web:**
   - I27;
   - errores de anular y corregir cargos;
   - la regla del botón de WhatsApp;
   - el portal del inquilino;
   - foco y `maxLength`;
   - fallas visibles;
   - tiempo de Vitest y el enlace del pie;

    - más cobertura de punta a punta y pruebas del borde.
6. **Documentación:** ADR-0002, ADR-0006 y ADR-0007; SPEC sobre `load-tax-config`; el límite de 5 MB.

Con cada historia:

- la deuda de la API antes de CS-15;
- el retiro del consentimiento y la purga en CS-25;
- "Meses pagados" en CS-23.

Decisiones tuyas (regla 2), con mi recomendación

1. **I22, volver a recibir los recordatorios:** una casilla en Mis datos que quite la baja propia, con DELETE en `email_suppressions` para `casero_app` (tabla de roles y AR-14).
2. **I23, contrato por adelantado:** permitir terminarlo hoy aunque no haya empezado; se anulan sus rentas y lo cobrado queda "a devolver".
3. **I24, aviso al anular:** implementarlo ahora como cierre de CS-34, sin puntos extra, en anulaciones de cobros y de cargos. Por ejemplo: "Ya registraste un pago a SUNAT de {periodo}. Con esta anulación, lo que declaraste ya no coincide: revisa la tarjeta de ese mes en Formularios de SUNAT."
4. **I25, base declarada:** el formulario de pago a SUNAT pide confirmar el "Monto declarado (base)", prellenado y editable, y se guarda lo confirmado.
5. **Textos y confirmaciones:**
    - un texto neutro cuando la base sube sin dinero nuevo: "La base de {periodo} subió después de declarar…";
    - con el documento cambiado, contar como pagado lo que se pagó con el documento anterior y sacarlo del correo, para no pagar dos veces;
    - pedir confirmación para "Desactivar el enlace" y "Registrar devolución";
    - usar "Pagos recibidos" en vez de "Cobros" en la página de SUNAT.